MedBridge Health, Inc.
Information Security Policy

1. Purpose

The purpose of this policy is to establish security requirements for protecting MedBridge Health's systems, networks, and sensitive information from unauthorized access, misuse, and cybersecurity threats.

Since MedBridge Health provides telehealth services and handles Protected Health Information (PHI), keeping patient information secure is one of the company's main priorities.

This policy explains how MedBridge Health plans to manage cybersecurity risks, protect its information systems, and make sure employees understand their security responsibilities.

It also supports the company's efforts to meet applicable healthcare security and privacy requirements, including the HIPAA Security Rule, while improving its overall cybersecurity program.

---

2. Scope

This policy applies to all MedBridge Health employees, contractors, and third-party vendors who have access to company systems, networks, or sensitive information.

It covers employees working at the San Francisco office and those working remotely. Everyone with access to company resources is expected to follow the security requirements outlined in this policy.

The policy covers the following:

- **Company Devices:** Employee laptops, workstations, and other devices used for business operations.
- **Cloud Infrastructure:** Amazon Web Services (AWS), including systems used to host applications and store patient information.
- **Healthcare Applications:** Patient applications, clinician portals, and Electronic Health Records (EHR) systems.
- **Identity and Access Management:** Okta and other systems used to manage employee accounts and authentication.
- **Third-Party Services:** Google Workspace, Zoom for Healthcare, Twilio, Zendesk, and other services used for business operations.

- **Sensitive Information:** Protected Health Information (PHI), Personally Identifiable Information (PII), employee records, and confidential business information.

This policy applies regardless of whether company systems are accessed from the office or remotely.

Any exceptions to these requirements must be reviewed by the vCISO and approved through MedBridge Health's security exception process.

---

3. Roles and Responsibilities

Cybersecurity is a shared responsibility at MedBridge Health. Since the company does not have a dedicated security team, the IT Manager, part-time virtual Chief Information Security Officer (vCISO), and department leaders are responsible for managing different areas of the security program.

Each role has specific responsibilities to help protect patient information, manage cybersecurity risks, and make sure security requirements are followed.

3.1 Security Roles and Responsibilities

Role	Responsibilities
Chief Executive Officer (CEO)	Approves security policies, provides oversight of the security program, and makes decisions about accepting high-level business risks.
Chief Technology Officer (CTO)	Manages technical security risks, AWS infrastructure, healthcare applications, and engineering security controls.
Virtual Chief Information Security Officer (vCISO)	Oversees the security program, develops security policies, coordinates risk assessments, and reviews security compliance.
IT Manager	Manages employee devices, user accounts, network security, system backups, and access to company systems.
Privacy Officer (COO)	Oversees HIPAA privacy compliance, protects patient information, and coordinates breach notification activities when required.

Role	Responsibilities
HR Manager	Manages employee onboarding, offboarding, and security awareness training records.
Employees and Contractors	Follow company security policies, protect sensitive information, and report suspicious activity or potential security incidents.

3.2 Security Governance and Accountability

- The vCISO is responsible for coordinating MedBridge Health's security program and working with department leaders to identify and address security risks.
- The IT Manager handles day-to-day security activities, including managing employee access, maintaining devices, and supporting system security.
- The CTO is responsible for technical security decisions, while the Privacy Officer focuses on protecting patient information and meeting HIPAA privacy requirements.
- The CEO provides oversight and approves major security policies and decisions involving high-level business risks.
- Employees and contractors are expected to follow company security requirements and report any suspicious activity or potential security incidents to the IT Manager or vCISO.

Clearly assigning these responsibilities helps MedBridge Health keep track of security issues and make sure the appropriate people are responsible for addressing them.

---

4. Policy Statements

MedBridge Health requires employees, contractors, and authorized third-party vendors to follow the company's security requirements when accessing or handling company information.

These requirements are intended to help protect patient information, reduce cybersecurity risks, and support the company's security and compliance responsibilities.

4.1 Information Security Governance

1. The vCISO must review the Information Security Policy at least once a year and update it when major changes occur.
2. The CEO must approve new security policies and any major changes to existing policies.
3. The vCISO must coordinate a cybersecurity risk assessment at least annually and document the identified risks.
4. Identified security risks must be assigned to a specific owner responsible for tracking and addressing them.

4.2 Data Protection

1. Employees must handle sensitive information according to MedBridge Health's data classification requirements.
2. Protected Health Information (PHI) must only be accessed by authorized personnel who need it to perform their job responsibilities.
3. PHI must be encrypted when transmitted over public networks and when stored in company-managed systems, using approved encryption methods.
4. Employees must not share PHI through unauthorized services, including personal email accounts or Slack.
5. Sensitive information must be securely deleted or disposed of when it is no longer needed, in accordance with applicable retention requirements.

4.3 Access Control

1. Employees must use individual accounts when accessing company systems.
2. Multi-Factor Authentication (MFA) must be enabled for workforce access to systems containing PHI and for administrative accounts.
3. User access must be approved by the appropriate system owner before access is granted.
4. The IT Manager must remove or disable employee access within 24 hours of a confirmed termination and immediately for high-risk departures.
5. User access permissions must be reviewed at least every six months.

4.4 Asset and Endpoint Security

1. The IT Manager must maintain an updated inventory of company laptops, applications, and critical IT systems.
2. Company-managed laptops must use full-disk encryption.

3. Employee devices must automatically lock after five minutes of inactivity.
4. Critical security patches must be applied within 14 days of release unless a documented exception is approved.
5. Only authorized and managed devices may access systems containing PHI.

4.5 Security Awareness and Training

1. All employees must complete security awareness training when they join MedBridge Health.
2. Employees must complete refresher security training at least once every 12 months.
3. The HR Manager must maintain records showing when employees complete their required training.
4. Employees must report suspicious emails, potential security incidents, or suspected unauthorized access to the IT Manager or vCISO as soon as possible.

4.6 Security Monitoring and Incident Response

1. Security logs for critical systems must be collected and retained according to an approved logging and retention schedule.
2. The IT Manager or designated technical staff must review high-priority security alerts at least once every business day.
3. Suspected cybersecurity incidents must be reported to the IT Manager or vCISO immediately after discovery.
4. MedBridge Health must maintain a documented incident response plan and review it at least once a year.
5. The Privacy Officer must coordinate the assessment of incidents involving PHI to determine whether breach notification is required.

4.7 Backup and Recovery

1. Critical production systems and patient data must be backed up at least once every 24 hours.
2. Backup restoration tests must be performed at least once every six months.
3. Backup access must be restricted to authorized personnel.
4. Backup failures must be investigated and documented by the responsible technical team.

4.8 Third-Party Risk Management

1. Third-party vendors must undergo a security review before receiving access to sensitive company information.

2. Vendors that qualify as HIPAA business associates must have a signed Business Associate Agreement (BAA) before handling PHI on behalf of MedBridge Health.
3. The Privacy Officer must maintain records of required vendor BAAs.
4. High-risk vendors must be reassessed at least annually.
5. Vendors must only receive the level of system access necessary to provide their services.

---

5. Exceptions

MedBridge Health understands that there may be situations where an employee or department cannot meet a specific security requirement due to technical limitations or business needs.

When this happens, an exception must be requested and approved before the employee or department is allowed to operate outside the policy.

5.1 Exception Request Process

1. Employees or department managers must submit a request explaining which security requirement cannot be met and why an exception is needed.
2. The request must identify the systems or information affected, any potential security risks, and how long the exception will be needed.
3. The vCISO must review the request, assess the security risks, and recommend additional safeguards when necessary.
4. The appropriate system owner must review the business need for the exception.
5. The CEO must approve exceptions involving high or critical risks. Lower-risk exceptions may be approved by the vCISO.
6. All approved exceptions must have an expiration date and be documented in the company's exception register.

5.2 Exception Monitoring and Review

The vCISO must review approved exceptions at least every 90 days to make sure the risks are still understood and any required safeguards remain in place.

Exceptions must be reviewed again before they expire. If an exception is no longer needed, the affected system or process must return to meeting the original security requirement.

Exceptions involving Protected Health Information (PHI) must also be reviewed by the Privacy Officer to make sure they do not conflict with applicable HIPAA requirements.

An approved exception does not remove MedBridge Health's legal or regulatory responsibilities.

---

6. Enforcement

All MedBridge Health employees, contractors, and third-party vendors are expected to follow the security requirements outlined in this policy.

Failing to follow these requirements could put patient information, company systems, and business operations at risk.

If someone violates this policy, MedBridge Health will review the situation and determine what action needs to be taken based on how serious the violation is.

Depending on the situation, corrective actions may include:

- **Additional Security Training:** Employees may be required to complete additional training to better understand their security responsibilities.
- **Written Warning:** Employees may receive a formal warning for failing to follow security requirements.
- **Access Restrictions:** Access to certain company systems may be temporarily restricted or removed.
- **Disciplinary Action:** Serious or repeated violations may result in further disciplinary action, including termination of employment.
- **Contractual Action:** Third-party vendors or contractors who violate security requirements may face consequences under their agreements with MedBridge Health.

The HR Manager will work with the appropriate department leaders when employee disciplinary action is needed.

The vCISO and IT Manager will review security-related violations and recommend actions to address any risks identified.

If a violation involves Protected Health Information (PHI), the Privacy Officer must also be notified to determine whether additional investigation or reporting is required.

MedBridge Health will handle policy violations consistently and consider the severity of the incident, its impact, and whether the violation was intentional or accidental.

---

7. Related Policies and References

MedBridge Health's Information Security Policy is based on cybersecurity standards, healthcare regulations, and security best practices that help the company protect sensitive information and manage security risks.

These references provide guidance for developing security requirements, managing cybersecurity responsibilities, and supporting compliance with applicable regulations.

7.1 Related Security Policies

The following policies support MedBridge Health's overall cybersecurity program:

- **Acceptable Use Policy:** Explains how employees and contractors are expected to use company devices, applications, and information.
- **Password and Authentication Policy:** Establishes requirements for passwords, Multi-Factor Authentication (MFA), and account security.
- **Incident Response Policy:** Defines how the company identifies, reports, investigates, and responds to cybersecurity incidents.

7.2 Regulations, Frameworks, and Standards

Reference	Purpose
HIPAA Security Rule (45 CFR Part 164, Subpart C)	Establishes security requirements for protecting electronic Protected Health Information (ePHI).
HIPAA Privacy Rule	Establishes requirements for protecting patient information and controlling how PHI is used and disclosed.
HITECH Act	Supports healthcare information security and breach notification requirements.
NIST Cybersecurity Framework (CSF) 2.0	Provides guidance for managing cybersecurity risks and improving security practices.
ISO/IEC 27001:2022	Provides requirements for establishing and managing an information security management system.
SANS Program Management Policy (February 2026)	Provides guidance for cybersecurity governance, leadership responsibilities, and program oversight.

7.3 Policy Review and Updates

The vCISO is responsible for reviewing this policy at least once a year to make sure it remains relevant to MedBridge Health's security needs.

The policy must also be reviewed when major changes occur, such as updates to healthcare regulations, new technology implementations, or changes to the company's security environment.

Any major changes must be approved by the CEO before the updated policy takes effect.

---

8. Definitions

This section explains some of the cybersecurity and compliance terms used throughout MedBridge Health's Information Security Policy.

Term	Definition
Protected Health Information (PHI)	Patient health information that can be used to identify an individual and is protected under HIPAA.
Electronic Protected Health Information (ePHI)	PHI that is created, stored, received, or transmitted electronically.
Personally Identifiable Information (PII)	Information that can be used to identify someone, such as their name, date of birth, or Social Security number.
Multi-Factor Authentication (MFA)	A security method that requires two or more authentication factors to verify a user's identity.
Virtual Chief Information Security Officer (vCISO)	An external security professional who helps manage an organization's cybersecurity program and security strategy.
Access Control	Security measures used to control who can access systems, applications, and sensitive information.

Term	Definition
Security Incident	An event that could affect the confidentiality, integrity, or availability of company systems or information.
Risk Assessment	The process of identifying and evaluating potential threats, vulnerabilities, and their impact on an organization.
Business Associate Agreement (BAA)	A contract required under HIPAA for certain vendors that handle PHI on behalf of a covered entity or business associate.
Data Classification	The process of organizing information into categories based on its sensitivity and protection requirements.
Policy Exception	A formally approved, temporary allowance to operate outside a specific security policy requirement.
Third-Party Vendor	An external company or service provider that supports MedBridge Health's business operations.

9. Document Control

This section documents the ownership, approval, and review requirements for MedBridge Health's Information Security Policy.

The vCISO is responsible for maintaining the policy and making sure it is reviewed regularly. The CEO is responsible for reviewing and approving the policy before it officially takes effect.

9.1 Policy Information

Field	Details
Policy Title	Information Security Policy

Field	Details
Organization	MedBridge Health, Inc.
Policy ID	MBH-ISP-001
Version	1.0
Policy Owner	Virtual Chief Information Security Officer (vCISO)
Policy Approver	Chief Executive Officer (CEO)
Effective Date	Pending Approval
Last Review Date	Not Yet Reviewed
Next Review Date	12 months after approval
Review Frequency	Annually
Policy Status	Draft — Pending Approval

9.2 Policy Review and Approval

The vCISO must review this policy at least once every 12 months or whenever major changes occur that could affect MedBridge Health's security requirements.

Any updates must be documented and submitted to the CEO for approval before the revised policy takes effect.

Employees and contractors must be informed of any changes that affect their security responsibilities.

9.3 Version History

Version	Date	Description	Updated By
1.0	November 2, 2026	Initial draft of the Information Security Policy	vCISO (Simulated)

9.4 Document Disclaimer

This Information Security Policy was created for a fictional healthcare organization as part of a hands-on GRC lab. All policy requirements, roles, and approval processes are simulated and do not represent an officially implemented security program.